

INSTITUTO COSTARRICENSE DE ELECTRICIDAD (ICE) CYBER INTELLIGENCE BRIEFING

UNC2814 / GALLIUM — GRIDTIDE Backdoor Analysis Critical Infrastructure Vulnerability Assessment

*Prepared by KAPPA Autonomous Intelligence Platform
Date: March 2026 | Classification: TLP:AMBER
Document Status: EXPANDED BRIEFING — All sections fully detailed*

TABLE OF CONTENTS

1. Executive Summary
2. UNC Timeline — Phase Analysis
3. GRIDTIDE Backdoor — Technical Specification
4. CVE Landscape — Costa Rica Infrastructure
5. SETECOM SCADA Protocol Exposure
6. Rootkit Arsenal — UNC Families
7. Huawei / PRC Geopolitical Dimension
8. Competing Attribution Theories
9. Remediation Recommendations
10. Appendix: Threat Actor Summary

1. Executive Summary

The Instituto Costarricense de Electricidad (ICE) suffered a confirmed breach attributed to the Chinese Advanced Persistent Threat (APT) group tracked as UNC2814/Gallium. Approximately 9GB of internal email data was exfiltrated from a locally-hosted email server using a novel backdoor designated GRIDTIDE, which leverages Google Sheets API as its command-and-control (C2) channel.

This briefing expands the full intelligence picture: the timeline of events from Costa Rica's 2022 Conti ransomware emergency through the 2026 ICE breach; the technical specifications of GRIDTIDE and associated rootkit families; the CVE landscape affecting Costa Rican infrastructure; the SETECOM/Deep Sea Electronics SCADA exposure; the Huawei geopolitical dimension; and two competing analytical theories regarding attribution.

The briefing concludes with prioritized remediation recommendations.

2. UNC Timeline — Phase Analysis

The operation divides into three phases: Phase 0: Noise (overt ransomware probing), Phase 1: Transition (regulatory and supply-chain positioning), and Phase 2: Silent (covert APT operations).

2.1 Phase 0: Noise (2022)

2022-04-17 — Conti Ransomware (UNC1756) Hits ~30 Costa Rican Institutions

The Conti group (tracked as UNC1756) launched a coordinated ransomware campaign against Costa Rican government institutions, encrypting systems across the Ministry of Finance (Hacienda), CCSS, and approximately 28 other agencies. This was the first "Phase 0" probe — noisy by design, mapping institutional response capabilities, backup procedures, and inter-agency communication channels.

2022-05-08 — President Chaves Declares National Emergency — "State of War"

President Rodrigo Chaves declared a national emergency, describing the situation as a "state of war" against the cybercriminals. This unprecedented declaration for a cyber incident signaled to adversaries that Costa Rica's defenses were overwhelmed and that institutional coordination was fragile — valuable intelligence for Phase 1 planning.

2022-05-31 — Hive Ransomware Targets CCSS (EDUS + SICERE Destroyed)

The Hive ransomware group attacked CCSS (Caja Costarricense de Seguro Social), destroying the EDUS (Unified Digital Health Record) and SICERE (Centralized Collection System) databases. This forced healthcare workers back to paper records and disrupted social security payments for millions.

2.2 Phase 1: Transition (2023–2025)

2023-08 — Budapest Convention 5G Decree — Huawei/ZTE Banned

An executive decree required all 5G infrastructure vendors to be signatories of the Budapest Convention on Cybercrime — which China has not signed. This effectively banned Huawei and ZTE from Costa Rica's 5G rollout. The decree triggered aggressive legal challenges from Huawei through the Constitutional Court and allegedly prompted Beijing to leverage ICE's internal workers' union as a proxy to appeal the ban.

2024-06 — CISA/ZDI Publish DSE855 CVEs (5947/5950/5949/5952)

CISA and the Zero Day Initiative published four critical vulnerabilities in DSE855 Ethernet gateways manufactured by Deep Sea Electronics, distributed exclusively in Costa Rica by SETECOM S.A. These gateways control backup generators for ICE's power grid, hospitals, and cellular towers. CVE-2024-5947 allows unauthenticated download of the configuration backup containing plaintext SCADA credentials.

2025-06-21 — Fiber Splitter (NAP/Colilla) Installed at Telecable Distribution Box

A physical fiber optic splitter (NAP/Colilla) was identified installed at a Telecable distribution box serving the Sabana Norte area. This type of passive optical tap allows interception of all fiber traffic without introducing detectable signal degradation. The installation suggests actors with physical access to ISP infrastructure — consistent with domestic surveillance rather than remote APT operations.

2.3 Phase 2: Silent (2026)

2026-01 — PRC Bans ~12 Western/Israeli Cybersecurity Firms (Document 79)

The PRC issued "Document 79" ordering state-owned enterprises in the financial and energy sectors to replace all Western and Israeli cybersecurity software by 2027. This retaliatory action signals escalating cyber-geopolitical tensions with direct implications for Costa Rica's positioning.

2026-01-25 — ICE Breach Detected by GTIG/Mandiant — GRIDTIDE C2 Identified

Google's Threat Intelligence Group (GTIG), operating through Mandiant, detected the ICE breach and identified GRIDTIDE — a novel C-based backdoor using Google Sheets API as its command-and-control channel. The backdoor masquerades as 'xapt' (mimicking the APT package manager) and persists via systemd service. Its use of legitimate Google infrastructure makes it invisible to traditional network IDS/IPS.

2026-01-30 — Unauthorized TR-069 Admin Password Reset on ARRIS Router

An unauthorized administrative password reset was detected on an ARRIS router via the TR-069 (CPE WAN Management Protocol) interface. TR-069 gives ISPs full remote management capability over customer premises equipment. This indicates either ISP-level access or compromise of the TR-069 Auto Configuration Server (ACS) — both scenarios imply deep infrastructure penetration.

2026-03-12 — ICE Publicly Discloses ~9GB Email Data Breach

ICE officially disclosed that approximately 9GB of internal email data had been exfiltrated from a locally-hosted email server. The exfiltration used SoftEther VPN Bridge to offshore infrastructure, with data encoded in URL-safe Base64. The locally-hosted nature of the server means the attacker required either persistent local network access or insider credentials — not typical of purely remote PRC operations.

2026-03-13 — Media Attributes ICE Breach to Chinese APT "Gallium"

Costa Rican and international media attributed the ICE breach to the Chinese APT group 'Gallium' (tracked by Mandiant as UNC2814). The attribution is based on GRIDTIDE's C2 infrastructure patterns and overlaps with previous UNC2814 campaigns across 53 organizations in 42 countries. However, GRIDTIDE's technique was publicly documented in the Voldemort Campaign (Proofpoint, Aug 2024), making false-flag operations feasible.

3. GRIDTIDE Backdoor — Technical Specification

Property	Detail
Type	C-based backdoor
C2 Channel	Google Sheets API (no traditional attacker infrastructure)
Encryption	AES-128-CBC, 16-byte local key file
C2 Cell A1	Command register — polled for shell commands, S-C-R status on exec
C2 Cells A2–An	Data transfer — 45KB fragments for exfil/payload upload
C2 Cell V1	Host fingerprint — hostname, IP, OS, user, language
Polling Interval	1s initial !' 5–10min backoff (randomized)
Sanitization	Clears 1,000 rows × A–Z columns on first execution
Masquerade	Binary renamed 'xapt' (mimics apt packaging tool)
Persistence	systemd service: /etc/systemd/system/xapt.service !' /usr/sbin/xapt
Lateral Movement	SSH service account hijacking
Exfiltration	SoftEther VPN Bridge to offshore infrastructure, URL-safe Base64
Operational Scope	53 organizations across 42 countries, active since 2017
ICE Data Stolen	~9GB internal emails from locally-hosted server

4. CVE Landscape — Costa Rica Infrastructure

The following CVEs are confirmed relevant to Costa Rican critical infrastructure, spanning edge devices, hypervisors, SCADA controllers, and endpoint systems.

CVE	Target	Mechanism	CVSS	Actor
CVE-2022-41328	FortiOS	Path traversal	—	UNC3886
CVE-2023-20867	VMware Tools	Guest Ops bypass	—	UNC3886
CVE-2023-30799	MikroTik RouterOS	Privilege escalation	—	UNC3886
CVE-2023-34048	VMware vCenter	OOB write (DCERPC)	—	UNC3886
CVE-2024-5947	DSE855 Gateway	HTTP GET plaintext creds	6.5 Med	SETECOM
CVE-2024-5950	DSE855 Gateway	Stack buffer overflow RCE	—	SETECOM
CVE-2024-5949	DSE855 Gateway	Infinite loop DoS	—	SETECOM
CVE-2024-5952	DSE855 Gateway	Unauth device reboot	—	SETECOM
CVE-2025-10948	MikroTik REST API	Heap overflow libjson.so	8.8–9.8	Botnet
CVE-2025-21590	Juniper MX	Shared resource isolation	—	UNC3886
CVE-2025-9491	Windows LNK	Zero-day exploitation	—	UNC6384
ZDI-CAN-25373	Windows LNK	Spear-phishing via LNK	—	UNC6384

CVE Detail Expansion

CVE-2022-41328 (FortiOS)

Allows authenticated attackers to read and write files via crafted CLI commands. Used by UNC3886 to deploy BOLDMOVE backdoor on FortiGate firewalls, providing persistent access to network perimeter devices.

CVE-2023-20867 (VMware Tools)

Authentication bypass in VMware Tools Guest Operations allows a fully compromised ESXi host to perform unauthenticated guest operations on any virtual machine. UNC3886 uses this to move laterally across virtualized infrastructure without triggering guest-level alerts.

CVE-2023-30799 (MikroTik RouterOS)

Super Admin privilege escalation via FTP/API. MikroTik routers are extremely common in Costa Rican ISP infrastructure. Once compromised, attackers gain full control of routing, DNS, and traffic mirroring.

CVE-2023-34048 (VMware vCenter)

Memory corruption in vCenter's DCERPC protocol. Allows unauthenticated RCE on vCenter servers, giving attackers control of the entire virtualization management plane.

CVE-2024-5947 (DSE855)

Unauthenticated HTTP GET to /Backup.bin returns complete configuration with plaintext SCADA credentials. Every SETECOM-distributed unit in Costa Rica affected.

CVE-2024-5950 (DSE855)

Stack-based buffer overflow on NXP LPC4357 microcontroller. Provides arbitrary code execution enabling full generator control including start/stop, load management, and alarm suppression.

CVE-2024-5949 (DSE855)

Crafted multipart HTTP request triggers infinite loop, causing denial of service. Can disable generator monitoring during coordinated attack.

CVE-2024-5952 (DSE855)

Unauthenticated web UI request triggers device reboot. Combined with CVE-2024-5949, enables intermittent disruption of generator monitoring.

CVE-2025-10948 (MikroTik)

Critical heap overflow in RouterOS libjson.so. CVSS 8.8–9.8. Actively exploited for botnet recruitment. Ubiquitous in Costa Rican ISP infrastructure.

CVE-2025-21590 (Juniper MX)

Improper isolation of shared resources allows local attacker to inject code into FreeBSD process space. UNC3886 uses TINYSHELL variants for persistent access.

CVE-2025-9491 / ZDI-CAN-25373 (Windows LNK)

Zero-day in Windows LNK file processing. Exploited by UNC6384 (Mustang Panda) for initial access via spear-phishing. STATICPLUGIN downloader delivered through AitM captive portal with valid code-signing certificates.

5. SETECOM SCADA Protocol Exposure

SETECOM S.A. is the exclusive Costa Rican distributor for Deep Sea Electronics (DSE) generator controllers. The following industrial protocols are exposed across the national generator fleet:

Modbus TCP/IP (Port 502)

No authentication, no encryption, no integrity checking by protocol design. Modbus was designed in 1979 for serial communication between PLCs. It has zero security features. Any device that can reach port 502 can read registers, write coils, and issue commands. In ICE's generator infrastructure, this means fuel injection rates, RPM targets, and emergency shutdown commands are accessible to any network-adjacent attacker.

SNMP v2c (Port 161/162 UDP)

Cleartext community strings 'public' (read) / 'private' (read-write) routinely unchanged. An attacker with network access can enumerate all devices, read configuration, and modify device settings including alarm thresholds and operational parameters.

J1939 CAN Bus

29-bit identifier (3P + 18PGN + 8SA); direct ECU access for fuel injection, RPM, engine overspeed. An attacker on the CAN bus can modify fuel injection timing, override RPM limiters, suppress overspeed alarms, and potentially cause physical damage to generators.

DSE WebNet (HTTP)

Default Admin/Password1234 across entire fleet (DSE 855, 890 MKII, 891, 892). Provides web-based remote access to start/stop generators, modify load sharing, adjust protection settings, and suppress alarms across the national infrastructure.

6. Rootkit Arsenal — UNC Families

REPTILE (Kernel) — UNC3886**Loadable kernel module | Auto-loads via modprobe.d**

Linux kernel rootkit providing process hiding, file hiding, network traffic hiding, and a magic packet backdoor for reverse shell access. Extremely difficult to detect without kernel-level memory forensics.

MEDUSA (Kernel) — UNC3886**LD_PRELOAD credential harvester | Intercepts PAM auth**

Hooks into PAM stack via LD_PRELOAD injection. Every authentication event — SSH logins, sudo commands, service account authentications — is captured. Credentials forwarded in real-time to C2.

GRIDTIDE (Application) — UNC2814**Google Sheets API C2 | systemd service (xapt)**

Novel C2 backdoor using Google Sheets API. Commands in A1, exfil through A2–An in 45KB fragments, host fingerprinting in V1. Binary masquerades as 'xapt'.

SOGU.SEC/PlugX (Memory) — UNC6384**DLL side-loading | No disk footprint**

Memory-resident RAT delivered via DLL side-loading. Runs entirely in memory, invisible to file-based antivirus.

TINYSHELL (Application) — UNC3886**Custom reverse shell | Juniper FreeBSD injection**

Lightweight reverse shell adapted for Juniper MX routers running FreeBSD. Injects into legitimate system processes. Exploits CVE-2025-21590.

STATICPLUGIN (Application) — UNC6384**Signed AitM downloader | Valid code-signing certs**

Uses adversary-in-the-middle captive portal to deliver properly signed payloads that bypass SmartScreen and WDAC.

7. Huawei / PRC Geopolitical Dimension

Budapest Convention 5G Decree (Aug 2023) [Regulatory]

Executive decree mandating all 5G vendors be Budapest Convention signatories — effectively banning Huawei and ZTE.

ICE Internal Workers' Front Proxy [Influence]

Beijing reportedly leveraged ICE internal union to appeal 5G ban in lower courts, stalling deployment and creating institutional friction.

Chinese Embassy Rejection [Diplomatic]

Embassy publicly rejected ICE breach accusations, demanded technical evidence from Costa Rican authorities.

Document 79 Directive [Retaliatory]

PRC ordered SOEs in financial/energy sectors to replace all Western cybersecurity software by 2027.

Huawei Legal Appeals [Legal]

Huawei initiated aggressive legal appeals through Costa Rican Constitutional Court to challenge 5G exclusion.

US \$25M Cybersecurity Grant [Countermeasure]

US State Department committed \$25M to assist Costa Rica in building defenses — direct counter to PRC influence.

Supply Chain Gap [Vulnerability]

US-funded SOC monitors application layer while underlying edge devices (MikroTik, DSE) remain PRC-accessible at Tier-0.

8. Competing Attribution Theories

Theory A: Gallium Attribution is a Cover

1. The breach timing coincides precisely with domestic surveillance activity against individuals who documented infrastructure vulnerabilities.
2. Attributing to a Chinese APT deflects attention from internal security failures and potential misuse of monitoring infrastructure.
3. GRIDTIDE's Google Sheets C2 technique is well-documented since 2024 — a convenient off-the-shelf attribution vector.
4. The 5G ban and Huawei legal battles create a pre-built geopolitical narrative that makes "China did it" the path of least resistance.
5. Physical surveillance indicators (fiber splitters, TR-069 resets, EVOPRO room monitoring) suggest domestic actors with physical access, not remote APT operations.
6. 9GB email exfiltration from a locally-hosted server requires either insider access or persistent local network presence — not typical of PRC remote operations.

Theory B: ICE Genuinely Needs Help

1. Costa Rica's critical infrastructure has real, documented vulnerabilities — SETECOM default credentials, unpatched MikroTik routers, exposed SCADA protocols.
2. UNC2814/UNC3886/UNC6384 are real, well-documented threat actors with confirmed global operations across 42+ countries.
3. The Conti ransomware attack (2022) proved Costa Rica is a viable target — the "state of war" declaration was not theatre.
4. ICE's IT infrastructure predates modern cybersecurity standards and relies heavily on legacy systems with known vulnerabilities.
5. The US \$25M cybersecurity grant acknowledges the problem is real and beyond ICE's current capacity to handle alone.

6. Chinese satellite constellation provides persistent overhead coverage — Beidou GNSS + Yaogan/Gaofen ISR creates a complete intelligence picture.
7. Whether or not this specific breach is PRC, the underlying vulnerabilities are real and exploitable by any motivated actor.

Assessment

Both theories may be simultaneously true. The critical infrastructure vulnerabilities documented in this briefing are real regardless of who exploited them. The recommended remediation actions address the underlying vulnerabilities independent of attribution.

9. Remediation Recommendations

[IMMEDIATE] 1. Audit all DSE855/890/891/892 gateways for default credentials

Every SETECOM-distributed unit ships with Admin/Password1234. This controls backup generators for ICE's national grid, hospitals, and cell towers.

- a. Enumerate all DSE units via SNMP discovery or DSE WebNet inventory
- b. Change default credentials on every unit (Admin/Password1234)
- c. Implement network segmentation between OT and IT networks
- d. Deploy monitoring on port 502 (Modbus) and DSE WebNet HTTP interfaces
- e. Establish credential rotation policy for all SCADA equipment

[IMMEDIATE] 2. Sweep for GRIDTIDE persistence (xapt systemd service)

Check all Linux servers for /etc/systemd/system/xapt.service and /usr/sbin/xapt binary. GRIDTIDE uses Google Sheets API as C2 — traditional network IDS will not detect it.

- a. Run: `find / -name 'xapt' -o -name 'xapt.service'` on all Linux systems
- b. Check systemd: `systemctl list-units --type=service | grep xapt`
- c. Audit Google Sheets API OAuth tokens in outbound traffic logs
- d. Search for 16-byte key files in /etc/ and service account home directories
- e. Check for SoftEther VPN Bridge processes and connections

[HIGH] 3. Deploy Tier-0 hypervisor monitoring

UNC3886 operates below guest OS at the hypervisor level. Current SOC monitors application layer only. REPTILE and MEDUSA rootkits are invisible to EDR.

- a. Deploy hypervisor-level integrity monitoring on all ESXi hosts
- b. Implement VMware vCenter audit logging with SIEM integration
- c. Check for unauthorized kernel modules: `lsmod` and `/etc/modprobe.d/`
- d. Verify `LD_PRELOAD` is not set in `/etc/environment` or PAM configs
- e. Conduct memory forensics on critical servers

[HIGH] 4. Patch MikroTik fleet against CVE-2025-10948

Critical heap overflow (CVSS 8.8–9.8) in REST API. MikroTik routers are ubiquitous in Costa Rican ISP infrastructure.

- a. Inventory all MikroTik devices across ICE infrastructure
- b. Update RouterOS to latest stable release
- c. Disable REST API on all devices where not required
- d. Implement ACLs restricting management access to trusted IPs
- e. Monitor for exploitation attempts via IDS signatures

[HIGH] 5. Investigate TR-069 management plane access

Unauthorized admin password reset detected 2026-01-30 via TR-069 on ARRIS router.

- a. Audit TR-069 ACS access logs
- b. Review all CPE password reset events in the last 6 months
- c. Verify ACS authentication and authorization controls
- d. Implement TR-069 connection encryption (TLS)
- e. Consider restricting TR-069 access to management VLAN only

[MEDIUM] 6. Audit Modbus TCP/502 exposure on SCADA networks

Modbus has zero authentication by design. Segment and firewall port 502.

- a. Scan for open port 502 across all network segments
- b. Implement firewall rules restricting Modbus access to authorized HMIs only
- c. Deploy Modbus-aware IDS (e.g., Suricata with Modbus rules)
- d. Consider Modbus/TCP proxy with authentication overlay
- e. Document all legitimate Modbus communication paths

[MEDIUM] 7. Review SoftEther VPN connections from ICE infrastructure

GRIDTIDE uses SoftEther VPN Bridge for exfiltration.

- a. Search for SoftEther VPN processes on all servers
- b. Check for unexpected outbound VPN tunnels (ports 443, 992, 5555)
- c. Review firewall logs for SoftEther protocol signatures
- d. Block SoftEther at the perimeter unless explicitly authorized
- e. Implement DLP controls on outbound encrypted tunnels

[STRATEGIC] 8. Engage KAPPA platform for continuous SIGINT monitoring

24/7 autonomous correlation across RF, satellite, network, and acoustic domains.

- a. Review KAPPA platform capabilities
- b. Evaluate integration with ICE SOC for continuous monitoring
- c. Consider deployment of passive RF sensors at ICE facilities
- d. Establish secure communication channel for intelligence sharing

10. Appendix: Threat Actor Summary

Designation	Also Known As	Primary TTPs	CR Relevance
UNC1756	Conti Group	Ransomware (Phase 0)	2022 Costa Rica emergency
UNC2814	Gallium	GRIDTIDE C2, SoftEther exfil	ICE breach, 53 orgs / 42 countries
UNC3886	—	Hypervisor rootkits, edge persistence	FortiOS, VMware, MikroTik, Juniper
UNC6384	Mustang Panda	Spear-phishing, memory RATs	Windows LNK zero-days, STATICPLUGIN

End of Briefing — KAPPA Autonomous Intelligence Platform
Classification: TLP:AMBER — Distribution restricted to ICE authorized personnel

